Clair: Static Vulnerability Analysis for Containers

Hammam Kayed

October 1, 2026

Abstract

Clair is an open-source project designed for static vulnerability analysis of application containers. It analyzes the contents of container images and matches their components against known vulnerability information. This project discusses what Clair is, why it was developed, where and when it can be used, and how it works. It also presents a real-world cybersecurity problem that can occur in organizations in Palestine and proposes the use of Clair as a solution.

1 Introduction

Container technologies are widely used for developing and deploying modern applications. Container images may contain operating system packages, libraries, and other software components. Vulnerabilities in these components can introduce security risks.

Clair is an open-source project that provides static vulnerability analysis for application containers. Its purpose is to provide visibility into the security of container-based infrastructure by analyzing container image contents and identifying known vulnerabilities.

2 What is Clair?

Clair is an open-source vulnerability analysis project for application containers. It supports container images such as Docker and OCI images.

Clair performs static analysis of container image contents. Instead of executing the container, Clair analyzes the components contained within the image and matches them with known vulnerability information.

The main components of Clair are the Indexer, Matcher, and Notifier.

The Indexer analyzes the contents of a container image and produces an IndexReport. The Matcher uses this information to identify vulnerabilities and produces a VulnerabilityReport. The Notifier handles vulnerability-related notifications.

3 Why was Clair Developed?

Clair was developed to provide better visibility into the security of container-based infrastructure.

A container image can contain many software packages and dependencies. Some of these components may contain known vulnerabilities. Manually checking all components can be difficult, especially when organizations use many container images.

Clair provides an automated way to analyze container image contents and identify known vulnerabilities.

Therefore, Clair can help organizations identify vulnerable components before deploying containerized applications.

4 Where is Clair Used?

Clair is designed for container-based environments.

It can be used in environments involving:

- Docker containers.
- OCI container images.
- Container registries.
- Kubernetes environments.
- OpenShift environments.
- Container-based infrastructure.

Clair can also be deployed in distributed environments where its different services operate separately.

5 When is Clair Used?

Clair can be used whenever an organization needs to analyze a container image for known vulnerabilities.

For example, Clair can be used:

- Before deploying a container image.
- When a new container image is created.
- When an existing image is updated.
- When new vulnerability information becomes available.
- As part of a container security process.

The Matcher can periodically update vulnerability information. This allows Clair to use updated security-advisory information when performing vulnerability matching.

6 How does Clair Work?

Clair works through several cooperating services. The main components are the Indexer, Matcher, and Notifier.

The general workflow is:

Container Image → Indexer → IndexReport → Matcher → VulnerabilityReport → Notifier

6.1 Indexer

The Indexer analyzes the contents of a container image.

It examines the image and identifies its constituent components, including packages and other information about the image.

The result of this process is an IndexReport. The IndexReport describes the contents of the container image and can be used by the Matcher for vulnerability analysis.

6.2 Matcher

The Matcher is responsible for identifying vulnerabilities.

It takes the information obtained during indexing and matches the identified components against known vulnerability information.

The result is a VulnerabilityReport describing vulnerabilities associated with the container image.

6.3 Notifier

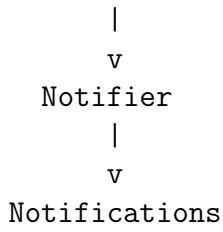
The Notifier handles vulnerability-related notifications.

When vulnerability information changes, the Notifier can be used to notify registered clients about affected container images.

7 Clair Architecture

The basic Clair architecture can be represented as follows:

```
Container Image
       |
       v
    Indexer
       |
       v
  IndexReport
       |
       v
    Matcher
       |
       v
VulnerabilityReport
```



This architecture allows the different Clair components to cooperate while performing different security-related tasks.

8 Problem in Palestine

A realistic cybersecurity problem that can occur in Palestine is the deployment of vulnerable container images by organizations such as universities, companies, software-development teams, or other institutions.

For example, an organization may develop a web application using Docker containers. The container image may contain an operating system, libraries, application dependencies, and other packages.

One of these components may contain a known security vulnerability. If the vulnerable image is deployed without being checked, the organization may introduce a known security weakness into its infrastructure.

This problem is related to software and cybersecurity supply-chain security because applications often depend on third-party software components.

9 Proposed Solution Using Clair

Clair can be introduced into the organization's container security process.

The proposed process is:

1. The development team creates a container image.
2. The container image is provided to Clair.
3. The Clair Indexer analyzes the image contents.
4. Clair creates an IndexReport.
5. The Matcher compares the indexed contents with known vulnerability information.
6. Clair generates a VulnerabilityReport.
7. The security or development team reviews the identified vulnerabilities.
8. Vulnerable components are updated when necessary.
9. The container image is rebuilt.
10. The updated image can be analyzed again before deployment.

This process provides an additional security check before the container image is deployed.

10 Example Scenario

Consider a Palestinian university that develops an online student-services application.

The application is packaged into a container image. The image contains the application and several software dependencies.

Before deploying the application, the university can analyze the container image using Clair.

The Indexer identifies the components inside the image. The Matcher then compares those components with known vulnerability information.

If a vulnerable component is identified, the development team can update that component and rebuild the container image.

The updated image can then be analyzed again before deployment.

11 Benefits of the Proposed Solution

Using Clair can provide the organization with better visibility into the security status of its container images.

The main benefits include:

- Identification of known vulnerabilities.
- Automated analysis of container image contents.
- Better visibility into container security.
- Detection of vulnerable components before deployment.
- Support for container-based security processes.

12 Conclusion

Clair is an open-source project for static vulnerability analysis of application containers.

The main Clair components are the Indexer, Matcher, and Notifier. The Indexer analyzes container image contents, the Matcher identifies vulnerabilities by comparing the indexed information with known vulnerability data, and the Notifier handles vulnerability-related notifications.

For an organization in Palestine that uses containerized applications, Clair can be used to identify known vulnerabilities before deploying container images.

The proposed solution is to analyze container images with Clair, identify vulnerable components, update those components, rebuild the image, and analyze it again before deployment.

13 References

1. Clair Project, "Clair: Open Source Vulnerability Static Analysis for Containers," GitHub. Available at: `https://github.com/quay/clair`
2. Clair Documentation, "Indexing." Available at: `https://github.com/quay/clair/blob/main/Documentation/concepts/indexing.md`

3. Clair Documentation, "Deployment." Available at: https://github.com/quay/clair/blob/main/Documentation/howto/deployment.md

4. Clair Documentation, "Configuration Reference." Available at: https://github.com/quay/clair/blob/main/Documentation/reference/config.md

5. WISLABi, "Security Articles." Available at: https://www.wislabi.com/publications/security-articles

6. WISLABi, "More – Tutorials and Scientific Writing Resources." Available at: https://www.wislabi.com/more